

FitPick AWS Deployment Handoff

Prepared for: DevOps

Prepared on: July 10, 2026

App path: /Users/Charles/Documents/fitpick

Deployment Target

FitPick is a Next.js App Router application with a separate background worker. The recommended AWS deployment for the current codebase is:

- EC2 for the web app and worker.
- PM2 for process management.
- MongoDB Atlas or managed MongoDB for application data.
- S3 for wardrobe photos and generated previews.
- CloudFront in front of S3 for public image delivery.
- Optional Nginx reverse proxy and HTTPS certificate on the EC2 instance.

Current App Processes

PM2 config is in `ecosystem.config.js`.

- `fitpick`: runs the Next.js production web server with `npm start`.
- `fitpick-worker`: runs `workers/fitpick-worker.ts` through `tsx`.

Use:

```
pm2 startOrRestart ecosystem.config.js --update-env
pm2 status
pm2 logs fitpick --lines 100
pm2 logs fitpick-worker --lines 100
pm2 save
```

Required AWS Services

EC2

Minimum practical setup:

- Ubuntu LTS instance.
- Node.js 20.x.
- npm.

- PM2 installed globally.
- Git access to the repository.
- Security group allowing HTTP/HTTPS inbound.
- SSH limited to trusted IPs.

Recommended:

- Nginx reverse proxy from port 80/443 to localhost:3000.
- HTTPS enabled before live payments.
- PM2 startup configured for reboot recovery.

S3

FitPick stores:

- Wardrobe uploads under wardrobe/<userId>/*.
- Generated previews under generated-previews/<userId>/*.

Use least-privilege IAM. The app needs object-level access for managed prefixes only:

- s3:PutObject
- s3:GetObject
- s3:DeleteObject

Reference policy: docs/deployment/iam-s3-fitpick-policy.json.

CloudFront

CloudFront should serve public image URLs for S3 assets. Prefer Origin Access Control and do not make the bucket broadly public.

Cache prefixes:

- wardrobe/*
- generated-previews/*

Set S3_PUBLIC_BASE_URL to the CloudFront distribution URL or production image domain.

Production Environment

Create .env.local on EC2. Do not commit it.

```
NODE_ENV=production
APP_URL=https://YOUR_DOMAIN
NEXT_PUBLIC_APP_URL=https://YOUR_DOMAIN
SESSION_COOKIE_NAME=fitpick_session
```

```

SESSION_COOKIE_SECURE=true
JWT_SECRET=

MONGODB_URI=

STORAGE_PROVIDER=s3
S3_BUCKET=
S3_REGION=
S3_ACCESS_KEY_ID=
S3_SECRET_ACCESS_KEY=
S3_PUBLIC_BASE_URL=

AI_TAGGING_PROVIDER=mock
GEMINI_API_KEY=
OPENAI_API_KEY=

ENABLE_BACKGROUND_JOBS=true
WORKER_POLL_MS=5000
AI_CACHE_PROVIDER=memory
RATE_LIMIT_PROVIDER=memory
RATE_LIMIT_REDIS_URL=

PAYMENT_PROVIDER=placeholder
STRIPE_SECRET_KEY=
STRIPE_WEBHOOK_SECRET=
FITPICK_PLUS_STRIPE_PRICE_ID=
STRIPE_SUCCESS_URL=https://YOUR_DOMAIN/plus?checkout=success
STRIPE_CANCEL_URL=https://YOUR_DOMAIN/plus?checkout=cancelled
PAYSTACK_SECRET_KEY=
PAYSTACK_PUBLIC_KEY=
PAYSTACK_WEBHOOK_SECRET=
FITPICK_PLUS_PAYSTACK_PLAN_CODE=
PAYSTACK_CALLBACK_URL=https://YOUR_DOMAIN/plus?checkout=success
NEXT_PUBLIC_PAYSTACK_PUBLIC_KEY=

```

Temporary EC2 IP testing may use:

```

SESSION_COOKIE_SECURE=false
APP_URL=http://EC2_PUBLIC_IP
NEXT_PUBLIC_APP_URL=http://EC2_PUBLIC_IP

```

Switch back to secure cookies when HTTPS is enabled.

Important Removed Feature

The `remove.bg` background-removal/studio-image feature has been removed from the codebase. Do not configure these variables:

```

BACKGROUND_REMOVAL_PROVIDER=
BACKGROUND_REMOVAL_API_KEY=
FITPICK_STUDIO_BACKGROUND_PRESET=

```

If an old EC2 `.env.local` contains them, remove them during deployment.

Deployment Commands

Run from the app directory on EC2:

```

git pull
npm install
npm run test:secret-scan
npm run test:safety-copy

```

```
npm run check:routes
npm run build:ec2
pm2 startOrRestart ecosystem.config.js --update-env
pm2 status
pm2 save
```

If dependencies are already installed and `package-lock.json` did not change, `npm install` is still acceptable for this repo. It should respect the lockfile.

Health Checks

After PM2 restart:

```
curl -I http://127.0.0.1:3000/api/health
pm2 logs fitpick --lines 100
pm2 logs fitpick-worker --lines 100
```

Expected:

- `/api/health` returns 200 OK.
- Web process stays online.
- Worker starts when `ENABLE_BACKGROUND_JOBS=true`.
- Worker exits cleanly only when `ENABLE_BACKGROUND_JOBS=false`.
- Logs show missing variable names only, never secret values.

Admin Operations Console

FitPick includes a production admin console at:

```
https://YOUR_DOMAIN/admin
```

The route is server-protected with `requireAdmin()` and only users with `role=admin` can access the console. Public, logged-out, and non-admin users receive the standard 404 page so the admin surface is not exposed as a reachable public screen.

Admin capabilities:

- System health overview for app, database, storage, and worker signals.
- Audit activity viewer using `/api/admin/audit`.
- Content readiness view using `/api/admin/content`.
- Controlled seed action using `/api/admin/seed`.

Before launch, create or promote at least one administrator user in MongoDB. Keep admin accounts limited, audited, and protected by strong credentials.

Smoke Test Checklist

Verify these flows after deployment:

- Register or log in.
- Load /home.
- Upload a wardrobe item.
- Review AI tags and save the item.
- Open wardrobe list and item detail.
- Choose an occasion.
- Generate an outfit recommendation.
- Save outfit.
- Mark outfit as worn.
- Open looks history.
- Open profile/preferences.
- Open Plus page.
- Open /admin with an admin account and verify health, audit, content, and seed controls.
- Run a checkout only in sandbox mode until HTTPS and webhooks are confirmed.

Payment Webhooks

Do not activate live payments until HTTPS is working.

Webhook endpoints:

- Stripe: `https://YOUR_DOMAIN/api/billing/webhook/stripe`
- Paystack: `https://YOUR_DOMAIN/api/billing/webhook/paystack`

Start with:

```
PAYMENT_PROVIDER=placeholder
```

Then move to stripe, paystack, or auto only after sandbox validation.

S3 CORS

Use this as a starting point and replace the origin:

```
[
  {
    "AllowedHeaders": ["content-type", "x-amz-*"],
    "AllowedMethods": ["PUT", "GET", "HEAD"],
    "AllowedOrigins": [
      "http://localhost:3000",
      "https://YOUR_DOMAIN"
    ],
    "ExposeHeaders": ["ETag"],
    "MaxAgeSeconds": 3000
  }
]
```

```
}  
]
```

Rollback

If deployment fails:

```
git log --oneline -5  
git checkout <previous-good-commit>  
npm install  
npm run build:ec2  
pm2 startOrRestart ecosystem.config.js --update-env  
pm2 save
```

After rollback, capture PM2 logs and create a fix branch before returning to the latest main branch.

Security Notes

- Never commit `.env.local`.
- Rotate any key pasted into chat, logs, screenshots, or shared documents.
- Keep `JWT_SECRET`, AWS keys, payment secrets, and OpenAI/Gemini keys server-only.
- Do not expose raw S3 errors, signed URLs, access keys, provider errors, or stack traces to users.
- Prefer CloudFront OAC over public S3 buckets.
- Restrict SSH and database network access.

Related Docs

- [docs/deployment/ec2-pm2-production.md](#)
- [docs/deployment/s3-cloudfront.md](#)
- [docs/deployment/background-workers.md](#)
- [docs/deployment/iam-s3-fitpick-policy.json](#)
- [docs/production-env-checklist.md](#)
- [docs/security/security-hardening.md](#)
- [docs/security/privacy-readiness.md](#)